

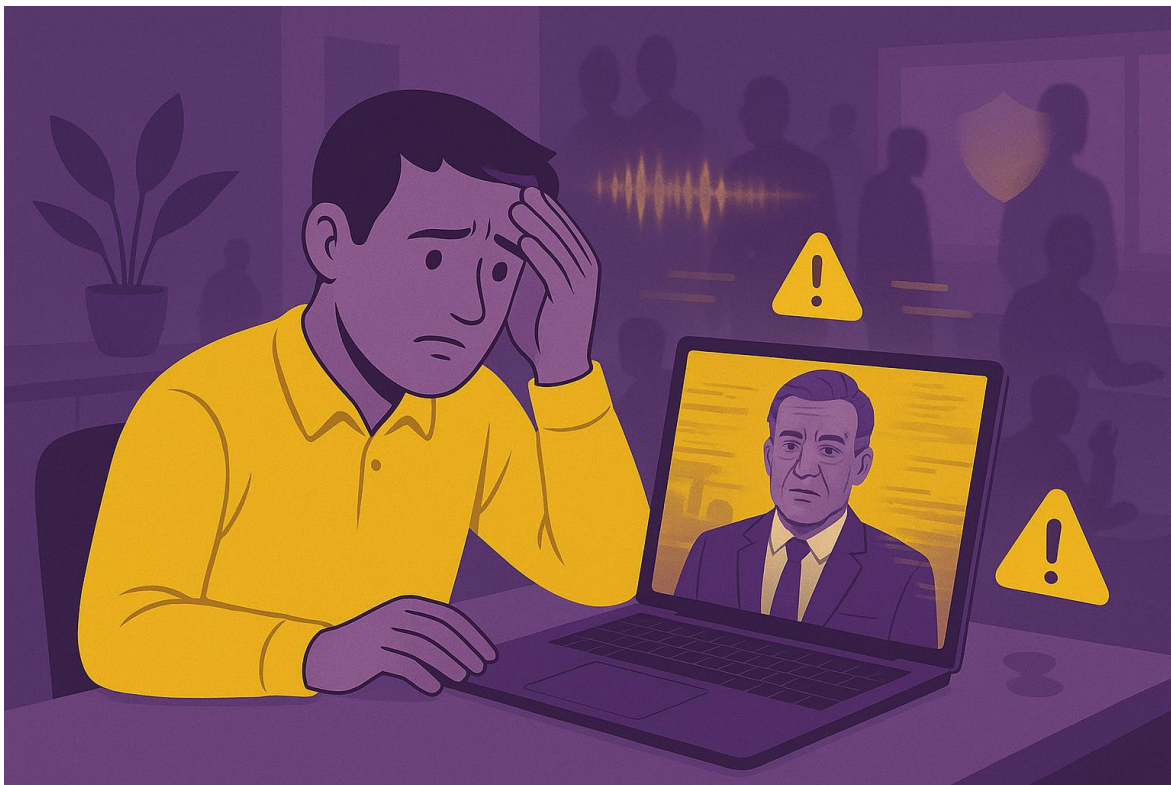
INCIDENT RESPONSE REPORT

Deepfake-Assisted Phishing Attack

Nomani Investment | Incident Date: April 18, 2026 | Classification: *CONFIDENTIAL*

Author: Adejoju Adewale | Security Operations Center

On April 18, 2026, a finance employee at Nomani Investment executed a malicious email attachment, installing malware that granted attackers remote access and triggered a C2 connection. The SOC contained the incident within 4 hours. No financial databases were altered; internal documents on the compromised endpoint were potentially exposed.



1. EXECUTIVE SUMMARY

On April 18, 2026, the Security Operations Center (SOC) at Nomani Investment detected suspicious outbound network traffic originating from a finance department workstation. Investigation confirmed that a phishing email carrying a malicious attachment had been

delivered to multiple employees earlier that morning. One employee opened the attachment, triggering malware installation that established unauthorized remote access and a command-and-control (C2) channel.

The SOC identified abnormal authentication activity, unauthorized PowerShell execution, and outbound C2 communications. Immediate containment workstation isolation, account disablement, and firewall blocks limited the blast radius. The incident was fully contained within four hours. No critical financial databases were altered and no verified customer data exfiltration occurred, though internal documents on the compromised endpoint were potentially exposed.

Post-incident, the organization enforced enhanced email filtering, mandatory multi-factor authentication (MFA), and additional phishing awareness training.

Severity HIGH	Status CONTAINED	Duration 4 Hours	Data Exfil NOT CONFIRMED
-------------------------	----------------------------	----------------------------	------------------------------------

2. BACKGROUND & SCOPE

Nomani Investment operates a finance-driven environment where employees process high-value transactions daily via email, phone, and internal approval workflows, making the finance department a prime target for social-engineering and phishing attacks.

Scope of Investigation

- Compromised employee workstation — forensic analysis
- Email server logs and phishing indicators of compromise (IOCs)
- Authentication logs and network activity during the incident window
- Affected user accounts and privilege escalation paths
- Lateral movement detection within the internal network
- Containment and remediation actions executed by the SOC

Systems outside the finance department environment were excluded unless directly linked to the incident.

3. ATTACK TIMELINE

TIME (UTC+1)	EVENT
07:42	Phishing email delivered to finance department staff via external SMTP relay
08:15	Employee opens malicious attachment; macro executes dropper payload

08:17	Malware establishes persistence (Registry Run key); begins credential harvesting
08:23	Outbound C2 connection initiated to 185.220.xxx.xxx (known malicious IP)
08:31	Attacker uses harvested credentials- first successful external login attempt
08:45	Lateral movement attempt via SMB; multiple failed authentication events logged
09:10	SIEM alert fires on abnormal PowerShell execution and unusual geo-login
09:18	SOC analyst confirms incident; escalation to IR lead
09:25	Workstation isolated from network; compromised account disabled
09:30	Malicious IP addresses blocked at perimeter firewall
11:42	Incident fully contained; post-incident review initiated

4. METHODOLOGY

The investigation followed the NIST SP 800-61 incident response lifecycle — Preparation → Detection & Analysis → Containment → Eradication → Recovery → Post-Incident Activity.

- **Log Collection:** SIEM alerts, endpoint logs, email server records, and firewall logs were aggregated for the incident window
- **Network Traffic Analysis:** Outbound connections were reviewed to identify C2 communication patterns and data staging activity
- **Endpoint Forensics:** The affected workstation was imaged; malware artifacts, persistence mechanisms, and execution traces were extracted
- **IOC Correlation:** Indicators (IPs, hashes, domains) were cross-referenced against threat intel feeds (VirusTotal, MISP)
- **Authentication Review:** Login attempts, MFA bypass events, and privilege escalation were mapped against Active Directory logs
- **MITRE ATT&CK Mapping:** Observed attacker behaviors were mapped to ATT&CK techniques for structured classification

5. FINDINGS

The investigation confirmed the following:

- Successful credential compromise of one finance department employee account
- Malicious macro in email attachment triggered dropper; malware established persistence via Registry Run key
- Unauthorized outbound connection to C2 server at 185.220.xxx.xxx on port 443 (SSL-wrapped)
- Suspicious PowerShell commands executed: encoded payloads consistent with Invoke-Mimikatz behavior
- Multiple failed and one successful login from an external IP (Eastern Europe geolocation)
- Attempted lateral movement via SMB to two adjacent workstations- blocked by endpoint controls
- No confirmed compromise of core financial databases or customer records
- Potential exposure of internal documents (contracts, budget sheets) stored on the infected endpoint

MITRE ATT&CK Technique Mapping

Technique ID	Name	Tactic	Observation
T1566.001	Spearphishing Attachment	Initial Access	Phishing email with malicious Office attachment
T1059.001	PowerShell	Execution	Encoded PowerShell used for payload execution
T1547.001	Registry Run Keys	Persistence	Malware persisted via HKCU Run key
T1003	OS Credential Dumping	Credential Access	Mimikatz-style credential harvesting observed
T1071.001	Web Protocols (C2)	Command & Control	HTTPS used to communicate with external C2
T1021.002	SMB/Windows Admin Shares	Lateral Movement	Attempted SMB-based movement to adjacent hosts
T1083	File and Directory Discovery	Discovery	Attacker enumerated file shares on endpoint

6. EVIDENCE COLLECTED

Evidence Item	Details / Analysis
Phishing Email Sample	Original email with malicious .docm attachment; sender spoofed internal HR address
Email Server Logs	SMTP delivery logs confirming receipt time (07:42) and affected recipients
SIEM Alerts	Correlated alerts: anomalous login, lateral movement attempt, C2 beacon pattern
Windows Event Logs	Event IDs 4624/4625 (logon success/fail), 4688 (process creation), 7045 (service install)
PowerShell Execution Logs	ScriptBlock logs showing encoded commands; consistent with Mimikatz invocation
Firewall Logs	Outbound HTTPS traffic to 185.220.xxx.xxx; blocked after C2 identification
EDR Telemetry	Process tree from malware execution; persistence artifact under HKCU\Software\Microsoft\Windows\CurrentVersion\Run
Authentication Logs	Successful login from IP geolocated to Eastern Europe at 08:31 UTC+1
File Access Records	Access to budget and contract documents on the compromised workstation during the incident window

7. RISK ASSESSMENT

The incident was rated HIGH severity based on successful credential compromise, active C2 communication, and attempted lateral movement within a finance-critical environment.

Risk Area	Impact	Likelihood	Risk Level	
Credential Compromise	High	High	High	HIGH
Malware Propagation	High	Medium	High	
Data Exposure (Internal Docs)	Medium	Medium	Medium	MEDIUM
Financial System Compromise	High	Low	Medium	MEDIUM

Business Disruption	Medium	Medium	Medium	MEDIUM
Reputational Damage	Medium	Low	Low	LOW

8. RECOMMENDATIONS

- **Enforce MFA Universally - Immediate:** Deploy MFA across all accounts, prioritising email, VPN, and admin consoles. Conditional Access policies should block logins from untrusted geographies.
- **Harden Email Gateway - Immediate:** Enable macro execution blocking for external Office attachments, deploy DMARC/DKIM/SPF enforcement, and implement sandboxed detonation for all inbound attachments.
- **Restrict & Monitor PowerShell - Short-term:** Apply Constrained Language Mode and enable Script Block Logging across all endpoints. Alert on encoded command execution (EncodedCommand flag).
- **Improve EDR Coverage - Short-term:** Enforce automated isolation policies on EDR for confirmed malware events. Ensure all finance department endpoints have full telemetry enabled.
- **Tune SIEM Detection Rules - Short-term:** Add rules for: geo-impossible logins, off-hours C2 beaconing patterns, Mimikatz-signature PowerShell commands, and abnormal SMB activity.
- **Implement Least Privilege Access - Medium-term:** Audit and reduce user privilege scope. Finance staff should not have local admin rights. Segment finance systems from general corporate network.
- **Run Phishing Simulations - Ongoing:** Deploy monthly phishing simulations targeting finance and HR staff. Track click rates over time and tailor training to failure patterns.
- **Conduct Regular IR Drills - Ongoing:** Tabletop and live-fire IR exercises quarterly to reduce mean-time-to-contain (MTTC). Current MTTC of 4 hours should be benchmarked and improved.

9. CONCLUSION

The security incident at Nomani Investment was successfully identified, contained, and remediated within four hours, preventing widespread compromise and confirmed customer data exfiltration. The root cause which is a phishing email carrying a malicious macro attachment exploited a gap in email filtering controls and user awareness.

While the attacker achieved initial access, credential harvesting, and a live C2 channel, rapid SOC detection and structured response limited the damage to a single endpoint. The attempted lateral movement was blocked before financial systems were reached.

Full enforcement of MFA, tighter email gateway policies, PowerShell restrictions, and regular phishing simulations are the highest-priority controls to prevent recurrence. This incident should serve as a trigger for a broader security posture review across all departments.

10. REFERENCES

- MITRE ATT&CK Framework — <https://attack.mitre.org> (technique mapping: T1566.001, T1059.001, T1547.001, T1003, T1071.001, T1021.002)
- NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide
- Internal SOC SIEM alert data and endpoint telemetry — Nomani Investment, April 18, 2026
- EDR console reports — endpoint forensics and process tree analysis
- Email security gateway and perimeter firewall logs
- VirusTotal / MISP — IOC correlation and threat intelligence enrichment